

Security Model

Section 1 - Roles

1.1 - Overview

This security model describes how authentication, authorization, and data protection are implemented and mapped to our non-functional requirements for confidentiality, integrity, availability, and accessibility.

1.2 - User & System Roles

We use a simplified form of role-based access control (RBAC), supported by clear and limited responsibilities. This minimizes potential vulnerabilities while keeping implementation achievable. Ownership-based access (users can only view or modify their own data) is applied wherever possible.

Role	Typical Actors	Core Permissions	Restricted Actions
Anonymous Visitor	Unauthenticated user	Browse public pages, view demo content, read privacy/terms	Access personalized features, save data, view others' information
Reader (Registered User)	End users reading news	Manage own profile and preferences, view simplified articles, save bookmarks, export/delete their own data, provide feedback	Access other users' data, change system configurations
Moderator	Team member maintaining quality	Review and remove flagged or inappropriate content (if enabled), monitor user feedback	Modify system-level settings, access confidential admin data
Admin	Maintainer or teaching staff	Manage users and roles, view audit logs, configure backups and settings	Disable security logging, access user passwords or secrets directly
Service (System Process)	Internal background process	Handle automated ingestion, caching, and analytics tasks	Access user data beyond defined scope

Key Principles

- **Least privilege:** Each role only gets the minimum access it needs.
- **Separation of duties:** Admins cannot act as reviewers for their own actions.
- **Accountability:** All sensitive actions are logged for review during development and testing.

1.3 - Authentication

- **Login method:** Email + password for Readers. Passwords stored using secure hashing (i.e. bcrypt).
- **Password policy:** Minimum 8 characters, must include multiple character types.
- **Session management:** Timeout after 30 minutes of inactivity; users reauthenticate for critical actions.
- **MFA:** Optional for users and required for Admins (e.g., via one-time code or authenticator app, if supported).
- **Account recovery:** Secure email-based reset link with time-limited validity.

1.4 - Authorization

- Access rules are enforced server-side based on role and ownership.
- Every user action is checked against permissions before data access or modification.
- Admin features are isolated from general user functionality to reduce accidental misuse.

1.5 - Data Protection and Privacy

Data Classification

- **Public:** Static pages and help documentation.
- **Internal:** Application logs, analytics data without personal identifiers.
- **Sensitive:** User profiles, saved bookmarks, feedback content.

Data Protection Measures

- **Encryption in transit:** HTTPS for all communication (TLS 1.2+).
- **Encryption at rest:** Handled via secure database storage (or local equivalent if hosted on student infrastructure).
- **Secrets management:** Environment variables or secure configuration files excluded from version control.

Data Retention

- User data retained for as long as the account is active; deleted upon request or after project completion.
- Log data kept for 90 days to assist debugging and then deleted.
- Backups performed periodically (manual or automated depending on hosting setup).

Privacy Principles

- Collect the minimum data required to provide functionality.
- Display clear consent at registration.
- Provide users the ability to export or delete their data.
- Respect all academic and ethical standards regarding data handling.

Third Party and AI Tools

- If AI summarization or news APIs are used, only minimal, non-personal content is shared.
- No personally identifiable information (PII) is sent to external APIs.
- Any third-party service used must comply with basic data protection standards (i.e. HTTPS, no data resale).

Logging and Monitoring

- Application logs include timestamps and pseudonymous user IDs.
- Sensitive actions (i.e. role changes, data deletions) are flagged for review.
- Logs are stored securely and only accessible to Admins.

Secure Development

- Use version control with protected branches (i.e. GitHub).
- Code reviews and peer testing before major merges.
- Regular dependency updates to fix vulnerabilities.
- Documented threat considerations and mitigations in sprint reviews.

Incident Handling

- In case of a data or access issue, the team will notify stakeholders (e.g., teaching staff) and document steps taken.
- Review and document root cause and prevention measures.

1.6 - Mapping to Non-Functional Requirements

Non-Functional Requirement	Measures Taken
Confidentiality	Encrypted data, role-based access, limited user information collection
Integrity	Input validation, audit logging, and restricted write access
Availability	Regular backups, reliable hosting environment, basic redundancy (if supported)
Accessibility	WCAG 2.1 AA design practices: screen-reader support, keyboard navigation, high contrast UI

Section 2 - Compliance Checklist

Requirement	Implementation Approach	Notes
PII protection	HTTPS, hashed passwords, role-based access control	Implemented within hosting limitations
User consent	Checkbox and terms link at registration	Stored in user profile data
Data export/delete	Profile page options for export and account deletion	Manual review for correctness
Data retention	Deleted after project completion or inactivity	Tracked in database cleanup scripts
Access control	Server-side checks, restricted admin pages	Unit tested for key endpoints
Audit logging	Sensitive events logged with timestamp	Logs stored securely
Backups	Regular database backups	Manual or automated depending on environment
Vulnerability management	Dependencies updated regularly	Logged in sprint reviews
Third-party API handling	Minimal data shared; HTTPS enforced	No user PII transmitted
Accessibility (WCAG)	Follows 2.1 AA principles	Verified with accessibility tools
Incident response	Document and notify stakeholders	Review within 24 hours
Key management	Environment variables and Git ignore policies	Shared securely within team

Appendix A - Permissions by Role

Capability	Anonymous	Reader	Moderator	Admin	Service
View public content	✓	✓	✓	✓	n/a
Register/login	X	✓	✓	✓	n/a
Manage profile and preferences	X	✓	✓	✓	X

Save bookmarks/reading list	X	✓	✓	✓	X
Export/delete own data	X	✓	✓	✓	X
Moderate content	X	X	✓	✓	X
Manage users and roles	X	X	X	✓	X
View audit logs	X	X	X	✓	X
Configure system settings	X	X	X	✓	X
Background processing	X	X	X	X	✓